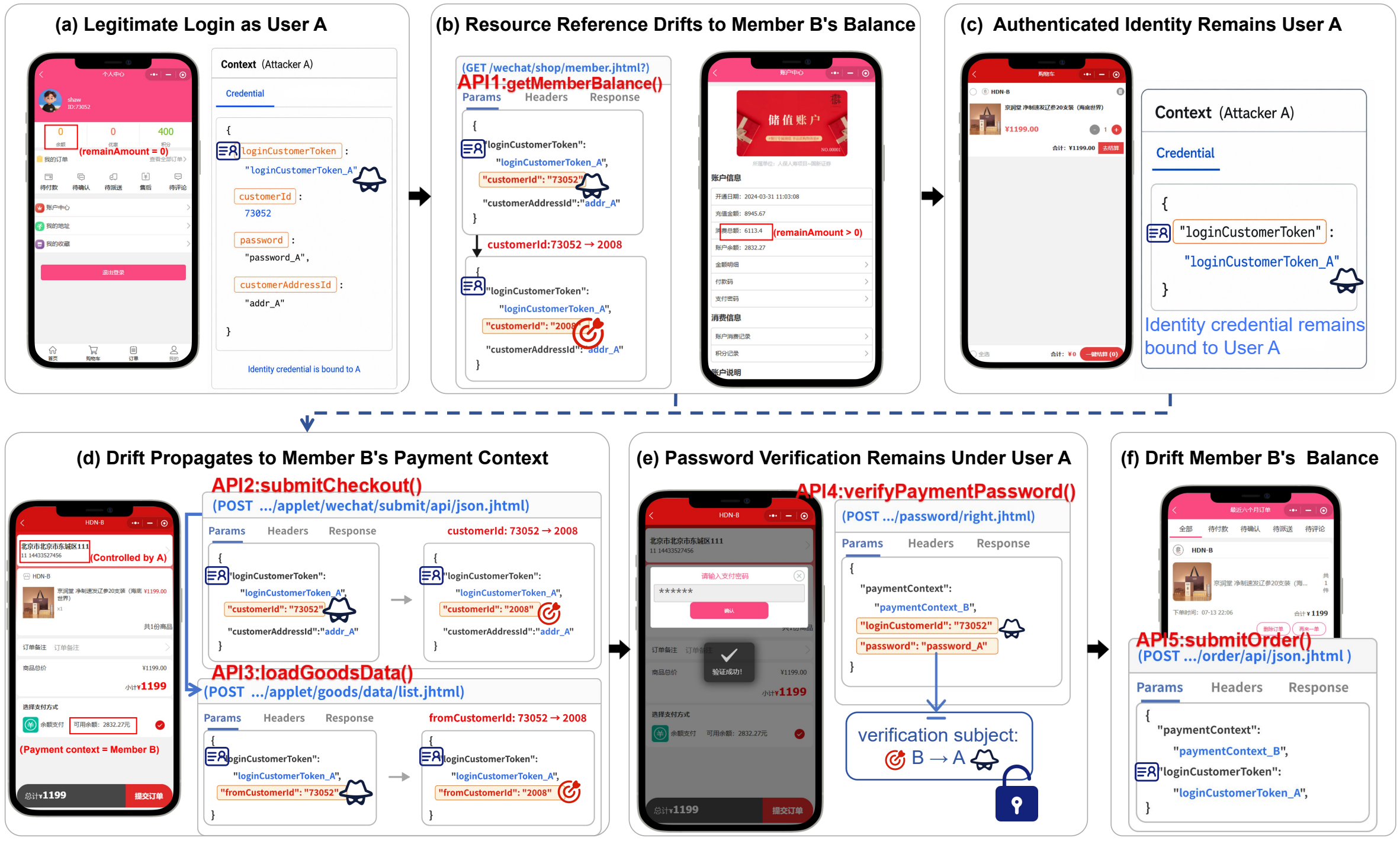

(a) Legitimate Login as User A
(remainAmount = 0)
Context (Attacker A)
Credential
{
loginCustomerToken :
"loginCustomerToken_A"
customerId :
73052
password :
"password_A",
customerAddressId :
"addr_A"
}
Identity credential is bound to A
(b) Resource Reference Drifts to Member B's Balance
(GET /wechat/shop/member.jhtml?)
API1:getMemberBalance()
Params Headers Response
{
"loginCustomerToken":
"loginCustomerToken_A",
"customerId": "73052"
"customerAddressId":"addr_A"
}
customerId:73052 → 2008
{
"loginCustomerToken":
"loginCustomerToken_A",
"customerId": "2008"
"customerAddressId": "addr_A"
}
储值账户
账户信息
(remainAmount > 0)
消费信息
(c) Authenticated Identity Remains User A
Context (Attacker A)
Credential
{
"loginCustomerToken" :
"loginCustomerToken_A"
}
Identity credential remains bound to User A
(d) Drift Propagates to Member B's Payment Context
API2:submitCheckout()
(POST .../applet/wechat/submit/api/json.jhtml)
Params Headers Response
customerId: 73052 → 2008
{
"loginCustomerToken":
"loginCustomerToken_A",
"customerId": "73052"
"customerAddressId":"addr_A"
}
{
"loginCustomerToken":
"loginCustomerToken_A",
"customerId": "2008"
"customerAddressId":"addr_A"
}
API3:loadGoodsData()
(POST .../applet/goods/data/list.jhtml)
Params Headers Response
fromCustomerId: 73052 → 2008
{
"loginCustomerToken":
"loginCustomerToken_A",
"fromCustomerId": "73052"
}
{
"loginCustomerToken":
"loginCustomerToken_A",
"fromCustomerId": "2008"
}
(Controlled by A)
(Payment context = Member B)
总计¥1199
提交订单
(e) Password Verification Remains Under User A
API4:verifyPaymentPassword()
(POST .../password/right.jhtml)
Params Headers Response
{
"paymentContext":
"paymentContext_B",
"loginCustomerId": "73052"
"password": "password_A"
}
verification subject:
B → A
(f) Drift Member B's Balance
API5:submitOrder()
(POST .../order/api/json.jhtml )
Params Headers Response
{
"paymentContext":
"paymentContext_B",
"loginCustomerToken":
"loginCustomerToken_A",
}